

Detecção de Acesso a Credenciais em Ambientes AD

Olá, meu nome é Cauã. Neste documento, apresento os fundamentos da detecção de ataques focados em acesso a credenciais no Active Directory (AD). O objetivo é preencher a lacuna analítica entre o momento em que um atacante obtém sua posição inicial e o instante em que ele compromete todo o domínio.

Contexto e Ameaças Relatórios recentes de resposta a incidentes (como os da DFIR e ReliaQuest em 2024) documentaram intrusões do ransomware BlackSuit, onde ferramentas como o Rubeus foram utilizadas para comprometer dezenas de contas — incluindo administradores de domínio — em uma única invasão. As técnicas utilizadas não são exóticas ou novas, mas sim métodos comuns, repetíveis e totalmente detectáveis para quem sabe monitorar o ambiente adequadamente.

Vetores de Ataque Abordados A investigação focará em cinco técnicas diretas que exploram a infraestrutura de autenticação e replicação do AD:

- Kerberoasting e AS-REP Roasting: Abuso do protocolo Kerberos para realizar a quebra de senhas de forma offline.
- Despejo do LSASS: Extração de credenciais ativas diretamente da memória do sistema.
- DCSync: Simulação de um Controlador de Domínio para extrair todos os hashes de senha do diretório.
- Extração do NTDS.dit: Cópia maliciosa do arquivo de banco de dados do AD diretamente do disco rígido do Controlador de Domínio.

Objetivos de Detecção

- Detectar *Kerberoasting* analisando solicitações TGS anômalas (especialmente utilizando criptografia RC4).
- Identificar *AS-REP Roasting* rastreando solicitações TGT em contas que possuem a pré-autenticação desativada.
- Sinalizar o comprometimento da memória LSASS observando padrões suspeitos de acesso a processos.
- Identificar ataques *DCSync* detectando solicitações de replicação não autorizadas no AD.
- Rastrear a extração do **NTDS.dit** por meio da criação de processos e gravação de arquivos nos Controladores de Domínio.
- Correlacionar artefatos nos logs dos hosts e dos Controladores de Domínio para rastrear com precisão o caminho de escalonamento do invasor.

O que foi realizado

- O que foi feito durante a atividade: Realizei a estruturação do cenário de investigação, mapeando os vetores de ataque focados no roubo de credenciais e definindo as abordagens de monitoramento com base em incidentes reais.
- Os principais conceitos aprendidos: O funcionamento das cinco principais técnicas de escalonamento em AD (Kerberoasting, AS-REP Roasting, despejo de LSASS, DCSync e extração do NTDS.dit) e o fato de que cada uma atinge uma parte distinta da infraestrutura, exigindo diferentes níveis de privilégios.
- Por que eles são importantes: Conhecer essas Táticas, Técnicas e Procedimentos (TTPs) é fundamental, pois elas representam a ponte entre o acesso inicial e o comprometimento crítico da rede. Correlacionar esses artefatos através de logs é o que permite detectar ferramentas agressivas e interromper operadores de ransomware antes que assumam o controle total do domínio.

Detecção de Ataques de Kerberoasting

Nesta etapa da investigação, concentrei-me no **Kerberoasting**, uma técnica de acesso a credenciais altamente explorada por invasores para preencher a lacuna entre o acesso inicial e o controle total do domínio.

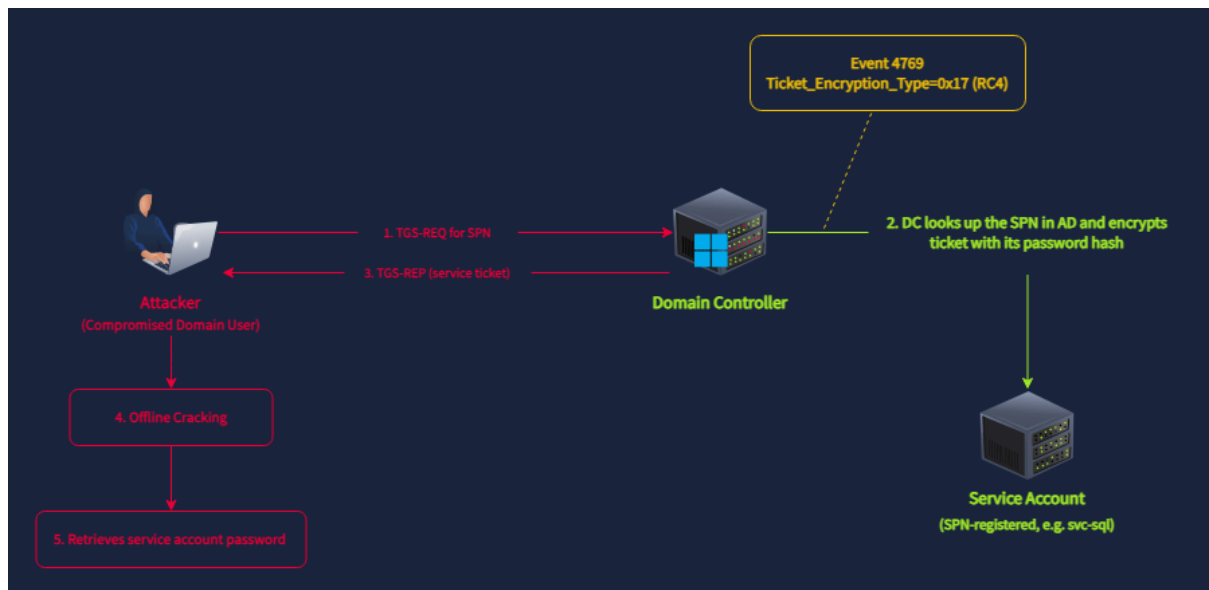
Atacantes visam contas de serviço através do Kerberoasting porque essas contas frequentemente possuem privilégios elevados (como uma conta de serviço SQL rodando como Administrador de Domínio) e senhas fracas. O comprometimento de uma dessas contas pode conceder controle total do domínio instantaneamente, e a execução do ataque exige apenas uma conta de usuário de domínio comum.

A Origem da Vulnerabilidade e o Fluxo do Ataque

O problema geralmente começa quando um administrador de TI configura um serviço utilizando uma conta administrativa com uma senha curta para facilitar a memorização. Ao registrar um **SPN** (Número de Programa de Serviço) nessa conta, o administrador vincula um hash de senha fraco a um serviço que qualquer usuário do domínio pode solicitar.

Quando um usuário precisa acessar um serviço no Active Directory, o fluxo funciona da seguinte forma:

1. O usuário solicita um tíquete de serviço Kerberos (TGS) ao Controlador de Domínio (DC).
2. O DC consulta o SPN, criptografa o tíquete com o hash da senha da conta de serviço e o devolve.
3. Como o DC não verifica se o usuário realmente tem permissão ou intenção de usar o serviço, ele simplesmente emite o tíquete.
4. Um invasor pode solicitar esse tíquete e utilizar ferramentas para quebrar a criptografia de forma offline. Em caso de senhas fracas, o atacante recupera a credencial em texto simples em poucos minutos.



Estratégia de Detecção: O Downgrade para RC4

A detecção desse ataque foca no **Evento 4769** (Kerberos Service Ticket Requested), registrado pelo Controlador de Domínio ao processar uma solicitação TGS-REQ.

Em ambientes modernos de AD, o padrão de criptografia para tíquetes Kerberos é o AES-256 (0x12). No entanto, ferramentas populares de Kerberoasting (como Rubeus e o `GetUserSPNs.py` do Impacket) rebaixam (*downgrade*) a criptografia da solicitação para **RC4** (0x17), pois hashes RC4 são substancialmente mais rápidos de quebrar. Portanto, uma requisição TGS com `Ticket_Encryption_Type=0x17` em um ambiente AES é um forte indicador de comprometimento.

Os campos essenciais do Evento 4769 que utilizei para a triagem no Splunk foram:

- **Service_Name**: O SPN solicitado (identifica a conta alvo).
- **Ticket_Encryption_Type**: Identifica a criptografia (0x12 AES ou 0x17 RC4).
- **Account_Name**: A conta que solicitou o tíquete (identifica o usuário comprometido/atacante).
- **Client_Address**: O endereço IP de origem da solicitação. *Nota: Em DCs modernos, este campo costuma exibir IPv4 mapeado para IPv6 (ex: ::ffff:10.5.90.1). O IP real é a porção final.*

Metodologia de Investigação no Splunk

Para isolar a atividade maliciosa no tráfego Kerberos (que é naturalmente ruidoso), excluí do filtro as contas de computador (*\$) e a conta `krbtgt`, focando apenas no indicador de rebaixamento RC4.

Splunk SPL

```
index=task2 EventCode=4769 Ticket_Encryption_Type=0x17 Service_Name!="*$"
Service_Name!="krbtgt"
```

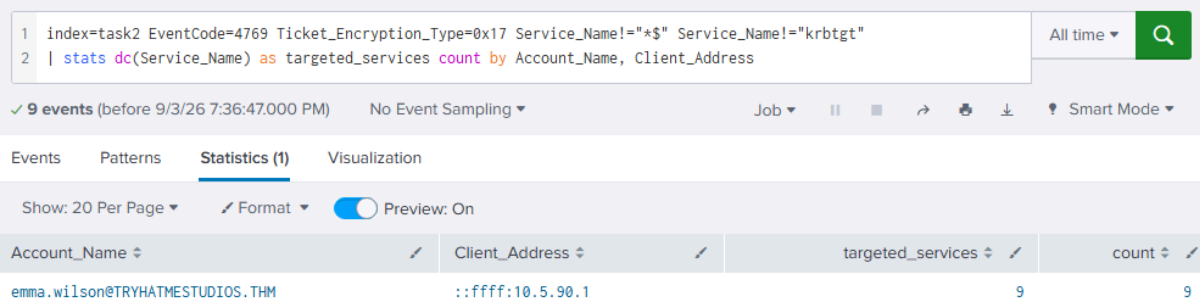
```
| table _time, Account_Name, Service_Name, Ticket_Encryption_Type, Client_Address  
| sort _time
```

O resultado revelou o padrão clássico do ataque: múltiplas requisições TGS utilizando RC4, partindo da mesma conta e direcionadas a diferentes serviços em um curto espaço de tempo.

Para refinar a triagem e consolidar as informações do atacante e das vítimas, apliquei agregações estatísticas:

Splunk SPL

```
index=task2 EventCode=4769 Ticket_Encryption_Type=0x17 Service_Name!="*$" Service_Name!="krbtgt"  
Service_Name!="krbtgt"  
| stats dc(Service_Name) as targeted_services count by Account_Name, Client_Address
```



Account_Name	Client_Address	targeted_services	count
emma.wilson@TRYHATMESTUDIOS.THM	::ffff:10.5.90.1		9

Evasão e Detecção Baseada em Volume

Descobri também que a detecção focada exclusivamente em RC4 não será suficiente a longo prazo. Ferramentas mais recentes, como o Orpheus, já realizam Kerberoasting utilizando AES-256, burlando o filtro 0x17. Além disso, a Microsoft está descontinuando o RC4 em novas versões (como o Windows Server 2025).

Para lidar com essa evasão, estruturei uma detecção baseada em **volume**. Como as ferramentas de ataque geralmente solicitam tíquetes para *todas* as contas com SPN no domínio, elas geram uma explosão anômala de solicitações. Agrupei os eventos em janelas de 5 minutos, alertando sempre que um usuário solicita tíquetes para mais de 5 serviços distintos nesse intervalo:

Splunk SPL

```
index=task2 EventCode=4769 Service_Name!="*$" Service_Name!="krbtgt"  
| bin _time span=5m  
| stats dc(Service_Name) as unique_spns count by Account_Name, Client_Address, _time  
| where unique_spns > 5
```

Evidências Extraídas (Questões Essenciais)

- **Pergunta:** Quantas contas de serviço foram alvo de Kerberoasting?

- **Resposta:** 9
- **Pergunta:** Qual conta solicitou os chamados de serviço? (Identificação do atacante)
 - **Resposta:** emma.wilson
- **Pergunta:** Qual endereço IP de origem iniciou o Kerberoasting?
 - **Resposta:** 10.5.90.1

O que foi realizado

- **O que foi feito durante a atividade:** Investiguei e comprovei a ocorrência de um ataque de *Kerberoasting* utilizando consultas estruturadas no **SIEM** (Splunk). Isolei tráfego malicioso filtrando o rebaixamento de criptografia (RC4) nos **logs** do Windows e desenvolvi uma técnica secundária de detecção baseada em volume para contornar novas ferramentas de evasão (AES-256).
- **Os principais conceitos aprendidos:** O funcionamento do ataque de *Kerberoasting* (focado no abuso da emissão de tíquetes TGS para contas com SPN); a estrutura e os campos críticos do Evento 4769 do Windows; o padrão comportamental de *downgrade* para criptografia RC4 (0x17); e a análise de IPs no formato de mapeamento IPv4/IPv6.
- **Por que eles são importantes:** Monitorar essas **TTPs** (Táticas, Técnicas e Procedimentos) é fundamental na resposta a incidentes. O *Kerberoasting* é uma técnica de pós-exploração ativamente utilizada por grupos de ransomware reais (como BlackSuit e Akira, destacados em relatórios da CISA/FBI) para obter controle do domínio. Correlacionar eventos de solicitação TGS ajuda a identificar precocemente o usuário comprometido e a mitigar o acesso de contas altamente privilegiadas (como Administradores de Domínio) antes que o hash seja quebrado offline.

Detecção de Ataques AS-REP Roasting

Enquanto o *Kerberoasting* foca em contas de serviço com SPNs registrados, o **AS-REP Roasting** explora uma vulnerabilidade distinta: contas de usuário com a pré-autenticação desativada (**DONT_REQUIRE_PREAUTH**). Esta técnica não exige SPNs e o invasor sequer precisa de credenciais válidas no domínio para executá-la — basta conhecer o nome de usuário vulnerável. O objetivo é obter material criptografado do Controlador de Domínio (DC) para quebrar a senha de forma offline.

O Fluxo de Autenticação e a Vulnerabilidade

- **Autenticação Kerberos Normal:** O usuário solicita um TGT enviando um carimbo de tempo criptografado com sua senha. O DC valida e emite o TGT, registrando o **Evento 4768** (**Pre_Authentication_Type=2**). Em seguida, ocorrem os Eventos 4769 (solicitação TGS) e 4624 (logon bem-sucedido).

_time	Account_Name	Pre_Authentication_Type	Ticket_Encryption_Type	Client_Address
2026-03-15 02:02:20	liam.patel	2	0x12	::ffff:10.5.50.20
2026-03-15 02:02:20	jessica.martinez	2	0x12	::ffff:10.5.50.15
2026-03-15 02:02:20	luke.sullivan	2	0x12	::ffff:10.5.50.10
2026-03-15 02:02:24	michelle.smith	2	0x12	::ffff:10.5.50.12

- **Ataque AS-REP Roasting:** Quando a conta tem a pré-autenticação desativada (uma configuração incorreta comumente mantida para suportar aplicações legadas, como sistemas ERP antigos), o DC ignora a etapa de verificação. Ele emite o TGT com um AS-REP criptografado pelo hash da senha da conta. O invasor captura esse hash e o quebra offline, sem nunca solicitar um tíquete de serviço ou realizar login.

O indicador claro desse ataque é o registro do **Evento 4768** com **Pre_Authentication_Type=0**, sem a presença subsequente de Eventos 4769 ou 4624 associados à conta.

_time	Account_Name	Pre_Authentication_Type	Ticket_Encryption_Type	Client_Address
2026-03-15 02:06:42	alex.reed	0	0x17	::ffff:10.5.90.1
2026-03-15 02:06:42	alex.reed	0	0x17	::ffff:10.5.90.1

Estruturação de Consultas SPL no Splunk Para detectar esse comportamento na prática, aprendi a estruturar consultas **SPL** (*Splunk Processing Language*) divididas em duas fases focadas em anomalias de logs:

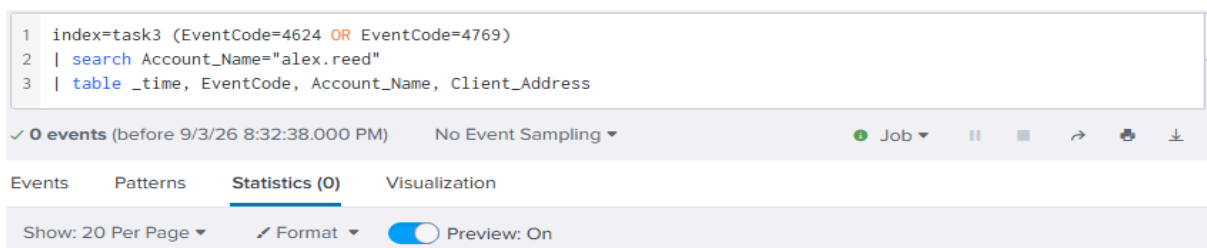
1. **Identificação de Requisições Anômalas:** A consulta busca isolar eventos de solicitação de TGT, filtrando pela ausência de pré-autenticação aliada ao uso de criptografia vulnerável (RC4, identificada como **0x17**).

Splunk SPL

- index=task3 EventCode=4768 Pre_Authentication_Type=0
 - | table _time, Account_Name, Pre_Authentication_Type, Ticket_Encryption_Type, Client_Address
2. **Validação de Intenção Maliciosa:** A segunda consulta serve para confirmar se houve atividade pós-solicitação, buscando eventos de login (4624) ou de serviço (4769) para a conta comprometida a partir da mesma origem.

Splunk SPL

- index=task3 (EventCode=4624 OR EventCode=4769)
 - | search Account_Name="{ACCOUNT_NAME}"
 - | table _time, EventCode, Account_Name, Client_Address
3. Se a consulta não retornar resultados, sugere fortemente que o TGT foi solicitado exclusivamente para extração e quebra offline do hash, descartando o acesso normal ao serviço.



No results found.

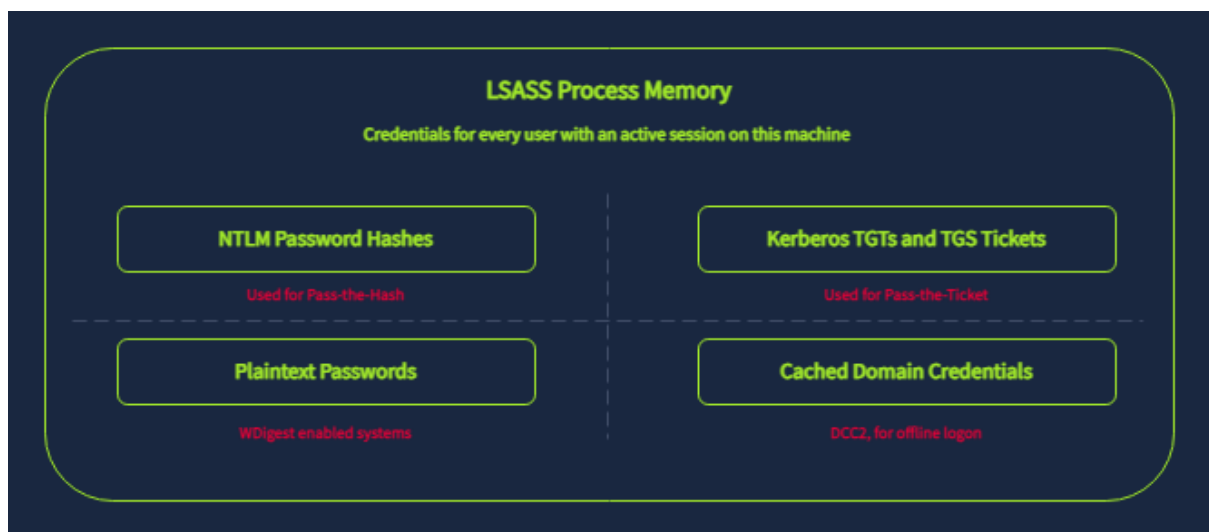
O que foi realizado

- **O que foi feito durante a atividade:** Estudei a mecânica do ataque de *AS-REP Roasting* e aprendi a construir consultas **SPL** no Splunk para detectar essas anomalias específicas nos logs do Windows.
- **Os principais conceitos aprendidos:** O impacto operacional da flag `DONT_REQUIRE_PREAUTH`, que permite o contorno da validação Kerberos. Compreendi as diferenças estruturais entre o *AS-REP Roasting* e o *Kerberoasting*, e como mapear a anomalia através do Evento 4768 com `Pre_Authentication_Type=0`, seguido pela validação da ausência de eventos subsequentes.
- **Por que eles são importantes:** Aplicações legadas frequentemente introduzem essa vulnerabilidade na rede, permitindo que invasores (como o grupo de ransomware BlackSuit, documentado pela The DFIR Report) obtenham hashes sem possuírem acesso prévio ao domínio. O monitoramento e o domínio na criação de pesquisas **SPL** no **SIEM** são essenciais para mapear logs e bloquear vias silenciosas de escalonamento de privilégios.

Detecção de Despejo de Credenciais LSASS

Diferente das técnicas que focam em eventos no Controlador de Domínio para quebrar senhas offline, o "dumping" do LSASS é uma técnica de roubo direto de credenciais que ocorre localmente, no endpoint (estação de trabalho ou servidor) onde as credenciais estão armazenadas.

Os atacantes visam o LSASS (Serviço de Subsistema de Autoridade de Segurança Local) porque ele armazena na memória as credenciais ativas de todos os usuários que se autenticaram naquela máquina. Se uma conta com privilégios elevados, como um Administrador de Domínio (DA), tiver uma sessão ativa, um atacante pode extrair seus hashes NTLM ou tíquetes Kerberos e obter controle imediato, sem a necessidade de quebrar senhas offline.



O que o LSASS armazena na memória:

- Hashes de senha NTLM de usuários autenticados.
- Tíquetes Kerberos (TGTs e TGS) para sessões ativas.
- Senhas em texto simples (quando o recurso *WDigest* está habilitado).
- Credenciais de domínio em cache para login offline.

Estratégia de Detecção com Sysmon (Evento 10)

A detecção do despejo de LSASS requer monitoramento local. O **Evento 10 do Sysmon** (*ProcessAccess*) é acionado quando um processo abre um identificador (*handle*) para outro processo (neste caso, o acesso ao *lsass.exe* por ferramentas como Mimikatz ou ProcDump).

Aviso Crítico: O Sysmon não registra esse acesso por padrão. É mandatório que a configuração inclua regras explícitas de *ProcessAccess* direcionadas ao *lsass.exe*. Em um ambiente sem essa configuração, o despejo do LSASS é invisível.

Os campos essenciais para investigar esse evento no Splunk incluem:

- **SourceImage:** Caminho completo do processo de origem (ferramenta usada para o despejo).
- **TargetImage:** Deve ser o alvo confirmado: *lsass.exe*.
- **SourceUser:** A conta que executou o processo. Uma conta comum executando despejo exige isolamento imediato do endpoint.
- **GrantedAccess:** Máscara hexadecimal revelando as permissões solicitadas.
- **CallTrace:** A cadeia da DLL (pilha de chamadas) que revela a técnica do ataque.

Interpretação Avançada de Logs (GrantedAccess e CallTrace)

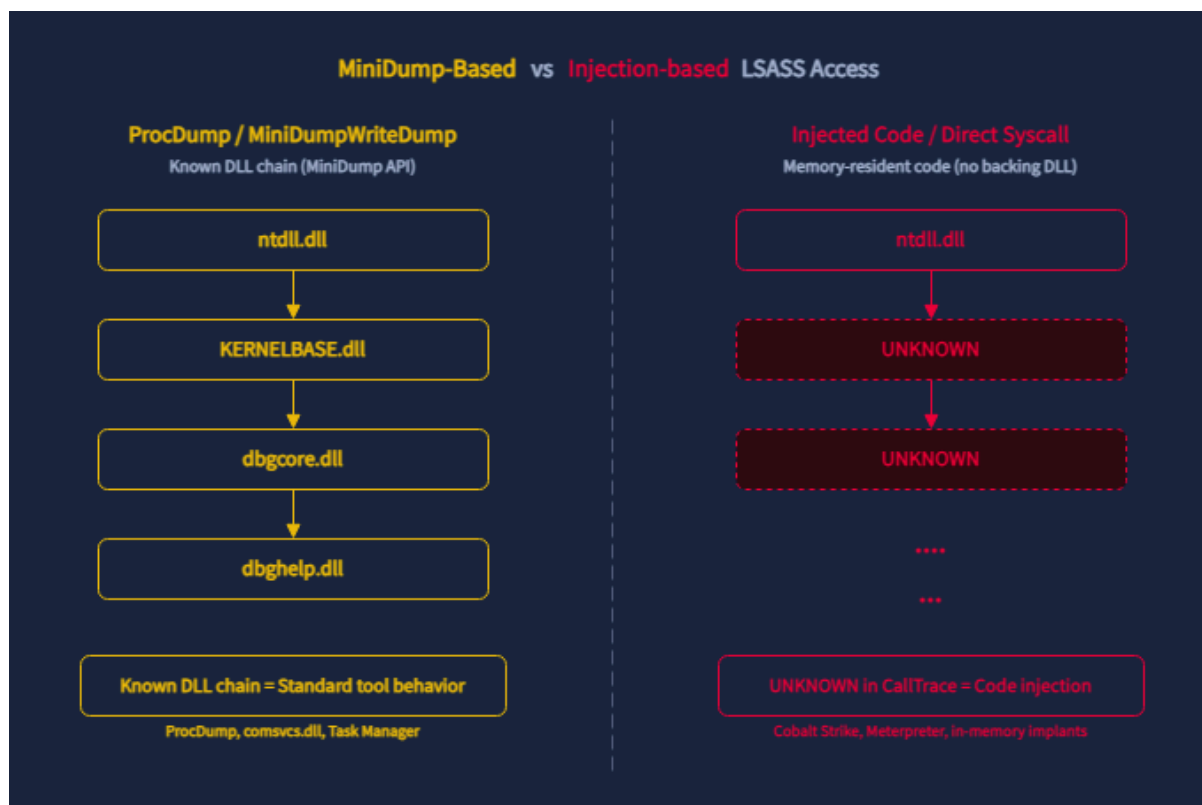
Entender os campos de log permite identificar exatamente a ferramenta do atacante e seu nível de sofisticação.

O **GrantedAccess** revela as permissões solicitadas:

- **0x1010** [0x1000 (Query) + 0x0010 (Read)]: Associado fortemente ao **Mimikatz**.
- **0xFFFFFFFF** [All Access]: Associado a **ProcDump**, *comsvcs.dll* e Gerenciador de Tarefas.

O **CallTrace** ajuda a distinguir a técnica utilizada:

- **Baseado em MiniDump:** Mostra DLLs legítimas como *dbgcore.dll* ou *dbghelp.dll*. Indica um invasor abusando de ferramentas nativas (LOLBins) como ProcDump.
- **Baseado em Injeção:** Mostra offsets **UNKNOWN** (endereços não mapeados para DLLs conhecidas). Esta é a assinatura de implantes complexos na memória e *beacons* (como Cobalt Strike ou Meterpreter).



Metodologia de Investigação no Splunk

Para investigar o incidente de despejo de LSASS, utilizei o Splunk para filtrar os processos que solicitaram acessos ao LSASS, discriminando processos normais do sistema de comportamentos maliciosos.

1. **Visão Ampla de Processos (Filtragem de Ruído):** Para não perder anomalias ao filtrar prematuramente por assinaturas maliciosas, levantei todos os processos que acessaram o LSASS:

Splunk SPL

```
index=task4 EventCode=10 TargetImage="*\\lsass.exe"
| stats count by SourceImage, GrantedAccess
```

2. Nesta etapa, descartei processos normais baseando-me **exclusivamente no caminho completo do arquivo**. Executáveis como `csrss.exe` ou `WerFault.exe` rodando a partir de `C:\Windows\System32\` são legítimos. Se o caminho for diferente, o artefato é suspeito, independentemente do nome do executável.
3. **Mergulho Profundo no Artefato Suspeito:** Após isolar o executável anômalo, aprofundi a análise investigando a máscara de acesso, a técnica utilizada na memória e a conta comprometida:

Splunk SPL

```
index=task4 EventCode=10 TargetImage="*\\lsass.exe"
SourceImage={SUSPICIOUS_PROCESS}
```

| table _time, SourcelImage, SourceUser, GrantedAccess, CallTrace

Evidências Extraídas

- **Evidência de Ferramenta e Localização:** Qual é o caminho completo do processo que acessou o `lsass.exe`?
 - **Resposta:** `C:\Windows\Temp\procdump64.exe`
- **Evidência de Capacidade de Leitura:** Qual valor de `GrantedAccess` foi usado?
 - **Resposta:** `0x1FFFFFF`
- **Evidência da Técnica (MiniDump vs. Injeção):** Qual DLL no `CallTrace` revela o método de despejo de memória?
 - **Resposta:** `dbgcore.dll`

O que foi realizado

- **O que foi feito durante a atividade:** Conduzi a investigação de um incidente focado na memória de um endpoint. Analisei os logs do Sysmon (Evento 10) no Splunk para identificar um processo anômalo abrindo identificadores de leitura no serviço LSASS, visando roubo direto de credenciais em cache.
- **Os principais conceitos aprendidos:** O funcionamento do armazenamento temporário de credenciais na memória pelo processo `lsass.exe` (Hashes NTLM e tíquetes Kerberos). Entendi a importância da configuração granular do Sysmon (regra `ProcessAccess`). Desenvolvi habilidades analíticas críticas ao aprender a interpretar as máscaras de bits no campo `GrantedAccess` e a cadeia de injeção de processos através do `CallTrace` para distinguir ferramentas nativas (LOLBins) de implantes injetados (como Cobalt Strike).
- **Por que eles são importantes:** O despejo do LSASS é uma **TTP** (Tática, Técnica e Procedimento) fundamental na cadeia de ataque de movimentos laterais (como *Pass-the-Hash* e *Pass-the-Ticket*), pois permite ao invasor assumir contas ativas — muitas vezes de Administradores de Domínio — sem a necessidade de exfiltração ou quebra de criptografia. Correlacionar esses indicadores de comprometimento (IOCs) no **SIEM** garante a contenção imediata de credenciais de alto privilégio. Incidentes reais, como a atuação do ransomware BlackSuit, baseiam-se em injetar *beacons* no LSASS para perpetuar sua posição na rede.

Deteccção de Ataque DCSync

Nesta etapa da cadeia de ataque, o invasor já obteve credenciais de Administrador de Domínio (seja através de Kerberoasting ou extração do LSASS) e possui o nível mais alto de acesso. O próximo objetivo é extrair todos os hashes de senha do domínio utilizando a técnica de DCSync.

O ataque DCSync permite que o invasor extraia as credenciais sem acessar o disco do Controlador de Domínio (DC), sem criar cópias de sombra de volume e sem acesso físico. A máquina do atacante explora o protocolo de replicação do Active Directory (DRSUAPI), passando-se por um controlador de domínio legítimo e solicitando a sincronização dos dados de senha. Se a conta possuir os direitos de replicação (padrão para Administradores de Domínio ou obtidos via abuso de ACL), o DC atende à solicitação.

A Mecânica dos Direitos de Replicação

A replicação do Active Directory baseia-se em direitos estendidos vinculados a GUIDs específicos. O principal indicador do DCSync é o uso da permissão

DS-Replication-Get-Changes-All, representada pelo GUID

1131f6ad-9c07-11d1-f79f-00c04fc2dcd2. É essa permissão que autoriza a extração dos dados de senha.

Monitoramento com o Evento 4662

A detecção do DCSync é fundamentada no **Evento 4662** (Uma operação foi realizada em um objeto), gerado pela auditoria de acesso ao Serviço de Diretório. Quando os direitos de replicação são exercidos, o evento registra o GUID correspondente em seus dados brutos.

Os campos essenciais para a investigação incluem:

- **user:** A conta executando a replicação.
- **Access_Mask:** O valor **0x100** indica que um direito ampliado (Controle de Acesso) foi exercido.
- **Properties:** Confirma o "Controle de Acesso" e contém os GUIDs de replicação no texto bruto do log.
- **Logon_ID:** Identificador de sessão vital para correlacionar o ataque com o Evento 4624 e descobrir o IP de origem.

Nota Crítica de Configuração: O Evento 4662 não é gerado por padrão. Sua existência depende de duas configurações manuais: (1) habilitar a "Auditoria de Acesso ao Serviço de Diretório" via Política de Grupo (GPO) e (2) configurar uma SACL na partição do domínio. Sem ambas, o ataque DCSync é completamente invisível nos logs.

Distinguindo Replicação Normal de Atividade Suspeita

Em ambientes com múltiplos DCs, a replicação gera eventos 4662 constantemente. A filtragem do ataque baseia-se na identificação de anomalias na origem da requisição:

Padrão	Tráfego Normal	Atividade Suspeita (DCSync)
Conta (user)	Conta de máquina (termina em \$, ex: THM-DC\$).	Conta de usuário humano (não termina em \$).
Origem	Outro Controlador de Domínio.	Estação de trabalho ou servidor comum.
Escopo	Alterações específicas de partição.	Solicitação de todas as credenciais (dump completo).

Metodologia de Investigação no Splunk

Para rastrear o ataque, utilizei o índice `index=task5` e dividi a investigação em duas fases de correlação de logs:

1. **Isolamento da Operação DCSync:** Filtrei o Evento 4662 buscando pela palavra-chave do GUID crítico (`1131f6ad`) e excluí contas de máquina (`user!="*$"`), isolando o usuário humano que executou a extração.

Splunk SPL

```
index=task5 EventCode=4662 "1131f6ad" user!="*$"  
| table _time, user, Access_Mask, Properties
```

2. **Aviso:** Em ambientes maduros, invasores podem assumir contas de máquina comprometidas para executar o DCSync, burlando o filtro `*$` e exigindo o monitoramento de todas as contas que replicam dados.
3. **Correlação de IP de Origem:** O Evento 4662 não revela o IP do atacante. Para descobrir a origem, extraí o `Logon_ID` do evento suspeito e o correlacionei com os logs de logon (Evento 4624):

Splunk SPL

```
index=task5 EventCode=4624 Logon_ID={LOGON_ID_ENCONTRADO}  
| table _time, host, user, Source_Network_Address, Logon_Type
```

_time ↕	host ↕	user ↕	Source_Network_Address ↕	Logon_Type ↕
2026-03-17 05:30:47	THM-DC	adm-luke.sullivan	10.5.90.1	3

Evidências Extraídas (Questões Essenciais)

- **Pergunta:** Qual conta realizou a sincronização do DataCenter (DCSync)?
 - **Resposta:** `adm-luke.sullivan`
 - **Explicação:** Identificada no campo `user` do Evento 4662 ao filtrar pela exclusão de contas de máquina e presença do GUID de replicação.
- **Pergunta:** Qual é o `Logon_ID` da sessão DCSync?
 - **Resposta:** `0x5A01668`

O que foi realizado

- **O que foi feito durante a atividade:** Investiguei um ataque de extração de credenciais via DCSync, analisando eventos do Serviço de Diretório no Splunk. Isolei a conta comprometida a partir de anomalias de replicação e correlacionei os **logs** do Evento 4662 com o Evento 4624 para rastrear o endereço IP de origem do atacante.
- **Os principais conceitos aprendidos:** O funcionamento da exploração do protocolo DRSUAPI; a importância crítica do GUID de replicação `1131f6ad`; a necessidade mandatória de configurar SACLs e GPOs para viabilizar a auditoria do Evento 4662;

e a lógica de correlação de identificadores de sessão (**Logon_ID**) entre diferentes IDs de log do Windows.

- **Por que eles são importantes:** O DCSync é uma técnica de comprometimento total e silencioso do diretório, utilizada ativamente por grupos reais (como o APT29 no caso SolarWinds e o grupo Scattered Spider). Como a técnica simula operações normais de replicação, dominar a correlação de **logs** e a filtragem de anomalias de contas de máquina é a única forma de rastrear e interromper o roubo massivo de identidades corporativas.

Detecção de Extração do NTDS.dit

Diferente do DCSync que opera remotamente mascarando-se como tráfego de replicação, a extração do arquivo **NTDS.dit** ocorre diretamente no Controlador de Domínio (DC). Embora seja uma abordagem mais antiga e ruidosa, continua sendo ativamente utilizada em intrusões reais para comprometer o banco de dados do Active Directory e extrair todos os hashes de senha do domínio.

O arquivo **NTDS.dit** (geralmente localizado em **C:\Windows\NTDS\ntds.dit**) fica bloqueado pelo Windows enquanto o AD DS está em execução, impedindo sua cópia direta. Para contornar essa proteção e obter o arquivo junto com a *hive* **SYSTEM** (necessária para descriptografar os hashes), os invasores utilizam dois métodos principais que exigem privilégios elevados:

- **Volume Shadow Copy (**vssadmin**):** Exige direitos de administrador local. O invasor cria um instantâneo (snapshot) do sistema de arquivos, copia os arquivos confidenciais ignorando o bloqueio e, em seguida, exclui a cópia de sombra para ocultar os rastros.
 - *Comandos típicos:* **vssadmin create shadow /for=C:**, seguido de comandos de cópia e **vssadmin delete shadows**.
- **Instalação a partir da Mídia (**ntdsutil**):** Ferramenta legítima do AD, mas que exige permissões de Administrador de Domínio. Explora o recurso IFM (Install From Media) para gerar cópias limpas do banco de dados e da hive **SYSTEM** em um diretório local.
 - *Comando típico:* **ntdsutil "ac i ntds" "ifm" "create full C:\temp" q q**

_time	host	User	ParentImage	Image	CommandLine
2026-03-18 07:57:13	THM-DC	NOT_TRANSLATED tryhatestudios\adm- luke.sullivan	C:\Windows\System32\cmd.exe	C:\Windows\System32\ntdsutil.exe	ntdsutil "ac i ntds" "ifm" "create full C:\Perflogs\l" q q

Lógica de Detecção e Uso do Sysmon

A identificação desse ataque foca na criação de processos anômalos e gravações de arquivos no disco do Controlador de Domínio. Caso o Sysmon não esteja presente, o Evento de Segurança 4688 do Windows (com registro de linha de comando ativado) fornece visibilidade semelhante.

- **Evento 1 do Sysmon (Criação de Processo):** Buscamos a execução de **ntdsutil.exe** com os argumentos **ifm** e **create**, ou o uso do **vssadmin.exe** contendo **create shadow**.

- **Evento 11 do Sysmon (Criação de Arquivo):** Captura o momento em que o arquivo `ntds.dit` é gravado em um local não padrão. A análise desse artefato específico está mapeada pelo **MITRE CAR-2019-08-002**.

Metodologia de Investigação no Splunk

Utilizando o índice `index=task6`, investiguei as duas técnicas de extração correlacionando a intenção dos comandos.

- **Investigando o abuso do `ntdsutil`:**
Busquei o uso do subcomando IFM através da captura da linha de comando completa:
`index=task6 EventCode=1 Image="*\ntdsutil.exe"`
Para validar se o arquivo foi realmente gerado, filtrei pela gravação do `ntds.dit` atrelada à imagem do `ntdsutil`:
`index=task6 EventCode=11 TargetFilename="*\ntds.dit" Image="*\ntdsutil.exe"`
- **Investigando a cópia sombra do `vssadmin`:**
Primeiro, identifiquei a criação da cópia de sombra:
`index=task6 EventCode=1 Image="*\vssadmin.exe" CommandLine="*create shadow*"`
Como backups legítimos também criam sombras, confirmei a intenção maliciosa procurando por comandos de cópia direcionados aos arquivos `ntds` ou `SYSTEM` dentro do snapshot:
`index=task6 EventCode=1 CommandLine="*HarddiskVolumeShadowCopy*"`
`(CommandLine="*\ntds*" OR CommandLine="*SYSTEM*")`

Comparativo: DCSync vs Extração NTDS.dit

Atributo	DCSync	Extração NTDS.dit
Método	Replicação remota via DRSUAPI	Cópia de arquivos locais via cópia sombra ou IFM
Acesso necessário	Direitos de replicação (DA por padrão)	Administrador local no DC ou permissão AD DS
Fonte de registro	Evento 4662 (Acesso ao Serviço de Diretório)	Eventos 1 (Processos) e 11 (Arquivos) do Sysmon

Visibilidade na rede	Tráfego de replicação vindo de um IP não-DC	Sem artefatos de rede (operação estritamente local)
Nível de ruído	Baixo (mistura-se com a replicação normal)	Alto (criação de cópias de sombra, gravações de arquivos)

<pre>1 index=task6 EventCode=1 CommandLine="HarddiskVolumeShadowCopy*" (CommandLine="*ntds*" OR CommandLine="*SYSTEM*") 2 table _time, host, User, ParentImage, Image, CommandLine</pre>					
2 events (before 9/3/26 11:02:00.000 PM) No Event Sampling					
Events Patterns Statistics (2) Visualization					
Show: 20 Per Page Format Preview: On					
_time	host	User	ParentImage	Image	CommandLine
2026-03-18 07:57:42	THM-DC	NOT_TRANSLATED tryhatmestudios\admluke.sullivan	C:\Windows\System32\cmd.exe	C:\Windows\System32\cmd.exe	cmd /c copy "\\?\GLOBALROOT\Device\HarddiskVolumeShadowCopy7\Windows\System32\config\SYSTEM" C:\Windows\Temp\system.save
2026-03-18 07:57:40	THM-DC	NOT_TRANSLATED tryhatmestudios\admluke.sullivan	C:\Windows\System32\cmd.exe	C:\Windows\System32\cmd.exe	cmd /c copy "\\?\GLOBALROOT\Device\HarddiskVolumeShadowCopy7\Windows\NTDS\ntds.dit" C:\Windows\Temp\ntds.dit.save

Evidências Extraídas

- Pergunta:** Qual é o caminho completo da cópia de sombra de onde o atacante copiou o arquivo ntds.dit?
 - Resposta:** `\\?\GLOBALROOT\Device\HarddiskVolumeShadowCopy7\Windows\NTDS\ntds.dit`
 - Explicação:** Encontrado filtrando os comandos de cópia associados ao volume HarddiskVolumeShadowCopy.
- Pergunta:** Onde o atacante armazenou os arquivos copiados da cópia de sombra?
 - Resposta:** `C:\Windows\Temp`

O que foi realizado

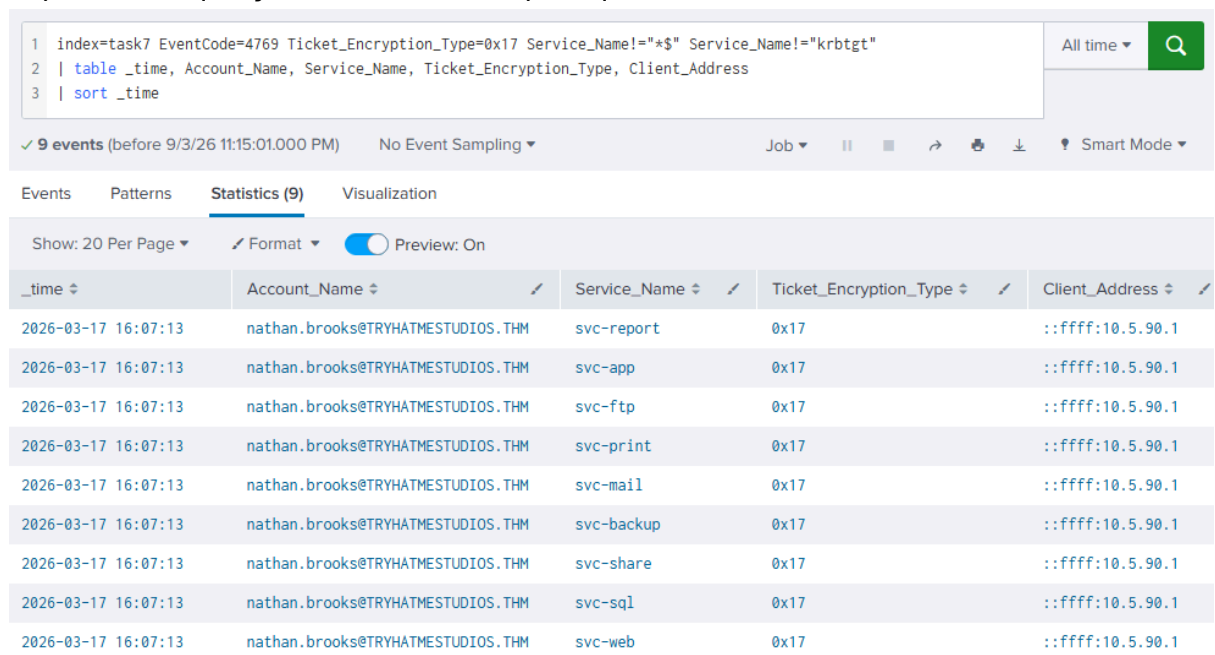
- O que foi feito durante a atividade:** Conduzi uma investigação sobre o roubo físico do banco de dados do Active Directory em um Controlador de Domínio. Utilizei o **Splunk** para rastrear comandos de criação de cópias de sombra e uso malicioso de ferramentas nativas de gerenciamento.
- Os principais conceitos aprendidos:** O funcionamento do bloqueio nativo do arquivo **NTDS.dit** e como os invasores utilizam o **vssadmin** e o **ntdsutil** (recurso IFM) para realizar *bypasses* locais. Mapeei essas atividades correlacionando a visibilidade de **logs** do Sysmon (Eventos 1 e 11) com execuções no terminal.
- Por que eles são importantes:** O acesso ao banco de dados **NTDS.dit** fornece ao atacante as chaves de toda a infraestrutura de TI. Identificar essas **TTPs** em um **SIEM**, apoiando-se em diretrizes como o **MITRE CAR-2019-08-002**, permite detectar o abuso de ferramentas nativas (LOLBins) a tempo de impedir a exfiltração do banco de dados para a quebra de senhas offline (com ferramentas como *secretsdump*).

Desafio de Investigação: Reconstrução de Cadeia de Ataque

Atuei na resposta a um alerta do SIEM referente a uma explosão de requisições TGS com criptografia RC4 em um intervalo de 60 segundos. O objetivo foi investigar a origem anômala e determinar a extensão do comprometimento utilizando o Splunk ([index=task7](#)).

Metodologia de Investigação

- **AS-REP Roasting e Kerberoasting:** Isolei os logs de autenticação Kerberos para identificar o alvo inicial (com pré-autenticação desativada) e a conta do atacante que disparou as requisições TGS anômalas para quebra de senha offline.

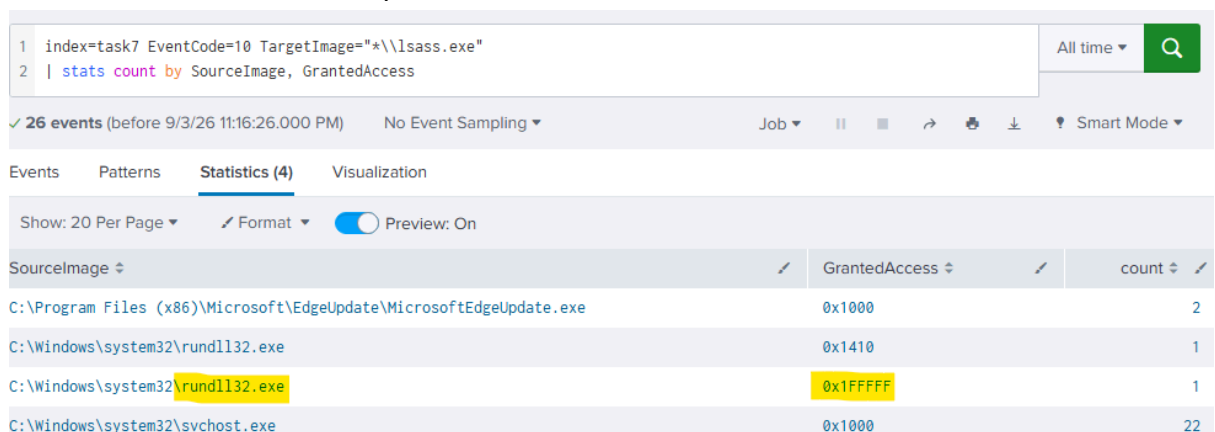


```
1 index=task7 EventCode=4769 Ticket_Encryption_Type=0x17 Service_Name!="*$" Service_Name!="krbtgt"
2 | table _time, Account_Name, Service_Name, Ticket_Encryption_Type, Client_Address
3 | sort _time
```

9 events (before 9/3/26 11:15:01.000 PM) No Event Sampling

_time	Account_Name	Service_Name	Ticket_Encryption_Type	Client_Address
2026-03-17 16:07:13	nathan.brooks@TRYHATMESTUDIOS.THM	svc-report	0x17	::ffff:10.5.90.1
2026-03-17 16:07:13	nathan.brooks@TRYHATMESTUDIOS.THM	svc-app	0x17	::ffff:10.5.90.1
2026-03-17 16:07:13	nathan.brooks@TRYHATMESTUDIOS.THM	svc-ftp	0x17	::ffff:10.5.90.1
2026-03-17 16:07:13	nathan.brooks@TRYHATMESTUDIOS.THM	svc-print	0x17	::ffff:10.5.90.1
2026-03-17 16:07:13	nathan.brooks@TRYHATMESTUDIOS.THM	svc-mail	0x17	::ffff:10.5.90.1
2026-03-17 16:07:13	nathan.brooks@TRYHATMESTUDIOS.THM	svc-backup	0x17	::ffff:10.5.90.1
2026-03-17 16:07:13	nathan.brooks@TRYHATMESTUDIOS.THM	svc-share	0x17	::ffff:10.5.90.1
2026-03-17 16:07:13	nathan.brooks@TRYHATMESTUDIOS.THM	svc-sql	0x17	::ffff:10.5.90.1
2026-03-17 16:07:13	nathan.brooks@TRYHATMESTUDIOS.THM	svc-web	0x17	::ffff:10.5.90.1

- **Despejo de LSASS:** Analisei o Evento 10 do Sysmon no endpoint comprometido para descobrir qual processo abriu um identificador para o `lsass.exe` e extraí a máscara de acesso utilizada para roubar as credenciais ativas em memória.



```
1 index=task7 EventCode=10 TargetImage="*\lsass.exe"
2 | stats count by SourceImage, GrantedAccess
```

26 events (before 9/3/26 11:16:26.000 PM) No Event Sampling

SourceImage	GrantedAccess	count
C:\Program Files (x86)\Microsoft\EdgeUpdate\MicrosoftEdgeUpdate.exe	0x1000	2
C:\Windows\system32\rundll32.exe	0x1410	1
C:\Windows\system32\rundll32.exe	0x1FFFFFF	1
C:\Windows\system32\svchost.exe	0x1000	22

- **DCSync:** Correlacionei eventos de acesso ao Serviço de Diretório para rastrear a conta que obteve privilégios máximos e simulou a replicação para extrair todos os

hashes do domínio.

1	index=task7 EventCode=4662 "1131f6ad" user!="*\$"	All tin
2	table _time, user, Access_Mask, Properties	
3	sort _time	

✓ 35 events (before 9/3/26 11:17:32.000 PM) No Event Sampling ▾ Job ▾ || ■ ↶ ↷ ⬇ ⚙ ⚡ Sn

Events Patterns **Statistics (35)** Visualization

Show: 20 Per Page ▾ ↗ Format ▾ ☒ Preview: On < Prev 1

_time ▾	user ▾	Access_Mask ▾	Properties ▾
2026-03-17 16:07:59	adm-luke.sullivan	0x100	Control Access
2026-03-17 16:07:59	adm-luke.sullivan	0x100	Control Access
2026-03-17 16:07:59	adm-luke.sullivan	0x100	Control Access
2026-03-17 16:07:59	adm-luke.sullivan	0x100	Control Access

Evidências Extraídas

- **Pergunta:** Qual conta foi alvo da campanha de AS-REP Roasting?
 - **Resposta:** mia.turner
- **Pergunta:** Qual conta realizou o ataque Kerberoasting?
 - **Resposta:** nathan.brooks
- **Pergunta:** Qual processo acessou o LSASS na estação de trabalho?
 - **Resposta:** rundll32.exe
- **Pergunta:** Qual valor GrantedAccess foi usado para o despejo do LSASS?
 - **Resposta:** 0x1FFFFFF
- **Pergunta:** Qual conta realizou o ataque DCSync?
 - **Resposta:** adm-luke.sullivan

O que foi realizado

- **O que foi feito durante a atividade:** Reconstruí uma cadeia completa de ataque no Splunk a partir de um alerta inicial do **SIEM**, investigando desde a exploração Kerberos até a extração de credenciais locais (LSASS) e do domínio (DCSync).
- **Os principais conceitos aprendidos:** A correlação prática de múltiplas técnicas avançadas de roubo de credenciais (AS-REP Roasting, Kerberoasting via RC4, LSASS Dumping e DCSync) operando em um cenário contínuo de intrusão.
- **Por que eles são importantes:** Em incidentes reais, um único alerta no **SIEM** geralmente representa apenas o início da intrusão. A capacidade de correlacionar **logs** para rastrear a evolução do ataque — desde o acesso inicial até o comprometimento total do diretório — é vital para dimensionar o escopo da violação e isolar todos os nós comprometidos na rede.